

Project management is the use of specific knowledge, skills, tools, and techniques to deliver something of value to people.¹²⁵ Effective project management includes established policies, standards, and procedures that project personnel apply enterprise-wide. Examples of projects include developing a new product or service, expanding into a new geographic market, and investing in a new system. When reviewing and prioritizing projects, effective management considers the project's effect on operations and the entity's needs (e.g., IT, information security, lines of business, customer needs, and regulatory and legal compliance). Entity projects often include a supporting IT project due to the underlying systems and components in business operations. For instance, when management considers offering a new product or service or expanding into a new geographic market, there are often IT implications. Effective IT project management processes, which are a subset of and align with the enterprise project management policies, standards, and procedures, should address issues specific to IT projects. Effective management develops and follows consistent processes to identify risks and oversee IT projects to address any risks identified. IT projects generally include IT system development, acquisition of a new IT system or component, or significant maintenance of or change to an IT product or service. If the entity has a PMO, IT project managers should work with the PMO to oversee and carry out IT projects.

An IT project should be managed in relation to the entity's size and complexity and consistent with the project's criticality and risks. An ineffectively managed IT project may result in late deliveries, cost overruns, or systems or components that do not meet entity, user, customer, or regulatory requirements. Systems or components that do not meet entity minimum standards or customer requirements can result in underused, insecure, or unreliable products or services. Adding functions, security, or automated controls into systems or components late in the initial development or after implementation to address missed requirements may incur substantial costs (e.g., personnel, time, and money), resulting in less effective systems or components. Furthermore, poor project management can lead to legal issues, such as violations of law and regulation and monetary penalties.

The project management discipline discussed in this section and the SDLC discipline discussed in the next section overlap significantly. In practice, effective system and component development teams integrate discipline use without duplicating effort.

IV.N.1 IT Project Phases

A general project management life cycle is shown in figure 3. The type of IT project (e.g., development, acquisition, or maintenance) will affect the project management life cycle chosen. For example, when an SDLC is chosen for a development project (e.g., adaptive versus predictive), the procurement processes chosen for an acquisition project, and the change control practices chosen for a maintenance project will affect how the project is managed. Furthermore, the activities completed within a project's life cycle are based on the characteristics of a project and the employed project management methodology.

¹²⁵ Refer to PMI's "[What Is Project Management?](#)"

Figure 3: Project Management Life Cycle



A project team often begins a project by creating a proposal to management that explains the business case including the desired system and component features and project scope, the planned benefits, the estimated time required, and the estimated cost.¹²⁶ Management reviews the proposal and determines whether the project is feasible and makes sense for the entity. If management approves the proposal and initiates the project, the business case serves as the basis for developing a detailed project plan.

The four main phases shown in figure 3 (Initiation, Planning, Execution, and Closeout) are described further in the following subsections.

IV.N.1(a) *Initiation*

The project's initiation phase begins with identifying stakeholders who determine the project's purpose, scope, and final deliverables. The following would typically be completed during this phase:

¹²⁶ PMI, [A Guide to the Project Management Body of Knowledge](#), fifth edition, p. 50.

- A project request that provides the business case including a description of the work, the benefits, alternatives considered, the impact of not doing the work, initial estimates of resources and schedule, and strategic match.
- A project charter that identifies the project owner (i.e., the responsible party), and defines the mission and main goals of the project.
- Initial business and technical requirements.¹²⁷

When the project involves developing a new system or component or making significant changes to an existing system or component, management analyzes and determines whether to develop or acquire (referred to as “build or buy”) the solution. A feasibility study¹²⁸ helps in the process of making this determination. Considerations in the feasibility study include availability of internal expertise, cost of building the solution compared with procuring it, availability of an external product that meets the entity’s requirements, solution implementation timeline, and the project’s complexity. Refer to table 2 in the “[Feasibility Study](#)” section of this document for additional feasibility considerations. Regardless of whether the decision is to build or buy, the feasibility analysis helps management to verify the reasonableness of the preliminary assumptions and to identify resource requirements in greater detail.

IV.N.1(b) *Planning*

In the planning phase, management forms a project team¹²⁹ that defines and refines project deliverables to achieve the objective and develops the project plan. Project plan common elements are tasks and milestones, task timelines, and names of those who are responsible for completing each task. Project teams engage stakeholders to define deliverables that achieve objectives and meet the entity’s functional, IT, information security, and legal and regulatory requirements. Requirements include systems, components, and resources that will support and interact with any new product or service. Clearly defined deliverables (including documentation deliverables) help stakeholders understand expectations. The project team should also define testing requirements and objective acceptance criteria, which are unbiased and predefined criteria for determining whether the project meets the stated objectives through milestones and project completion. Additionally, security and resilience design should be included from the beginning of the project to be most effective. Information regarding project management governance is in the *FFIEC IT Handbook’s* “[Management](#)” booklet.

¹²⁷ The NIST Glossary defines “[requirement](#)” as “a statement that translates or expresses a need and its associated constraints and conditions.”

¹²⁸ A feasibility study considers the critical aspects of a proposed project; assesses the degree to which the requirements, designs, or plans can be implemented; and helps determine the likelihood of the project’s success. A formal feasibility study may not be performed at smaller, less complex entities; however, management should perform some analysis of system or component needs for a given project.

¹²⁹ Depending on the IT project type and complexity, the project team may include multidisciplinary stakeholders from varying lines of business. An effective project team’s roles and responsibilities are clearly defined and communicated so everyone involved is aware of their responsibilities.

IV.N.1(c) *Execution*

During the project's execution phase, the project team completes the project plan tasks. The team tracks and compares actual task execution with the project plan, maintains a log of problems (e.g., inability to meet milestones, resource changes, and unanticipated risks), tracks problem resolution, reports on effects to the project timeline, and monitors interdependency issues. During the execution phase, scope creep is a common problem that can occur as developers address issues or receive subsequent requests to add or modify a system's features. It may result from inadequately defined requirements, a lack of a project change control process, inaccurate time and budget analysis, or a weak project manager or executive sponsor. Establishing change approval procedures during development and cutoff dates (after which time requested changes are deferred to subsequent versions) helps mitigate scope creep.

Strong change approval procedures enforced by management can mitigate the risks that come with scope creep. Procedures can include independent project monitoring for additions or modifications of functional and nonfunctional features to help enforce management review and approval. Procedures can also include project plan variance management reporting that could indicate scope creep (e.g., delays in completion of tasks or cost overruns). Significant project plan variances may require the entity to reassess and re-baseline project plans. Project managers regularly report the project's status to stakeholders, senior management, and, when appropriate, the board in order to inform of changes and issues.

Strong testing and other QC procedures can mitigate the risk that the entity's project goals and stakeholder requirements are not met during the execution phase. Testing helps find deficiencies or defects and helps ensure that the system or components operate as intended. Depending on the project type, testing may be scheduled throughout the project during any phase. For example, testing may not always occur during every sprint when using an agile development methodology. Users, designers,¹³⁰ developers, and IT staff may be involved in testing. Throughout the testing process, management should maintain comprehensive and accurate documentation reflecting the testing methodology employed, tests performed, and test results.

IV.N.1(d) *Closeout*

During the project's closeout phase, the project team delivers the agreed-upon scope items as outlined in the project plan. For example, in a systems development or acquisition project, project closeout is when the project team transitions the systems to the operations staff (i.e., moves application from a staging to a production environment). Often during the project closeout, project teams analyze the project (i.e., post-implementation review) to identify effective project practices and discuss issues encountered and how they were resolved. This information is used to inform and improve project management practices. Project teams review project documentation in the closeout phase to ensure that it is complete, supports maintenance, and can be used by future teams to identify effective practices.

¹³⁰ Designers may include personnel engaged in creation and execution of plans for a project or structure (e.g., graphic designers, web developers and digital designers, web and digital interface designers, computer programmers). See Bureau of Labor Statistics, [Occupational Outlook Handbook](#), for more information on job descriptions.

IV.N.2 Monitoring and Controlling

Monitoring and controlling are important parts of the processes of IT project management. This takes place throughout all phases of IT project development (refer to figure 3). Monitoring and controlling are helpful for tracking, reviewing, and evaluating the progress of an IT project. Monitoring and controlling helps management identify IT project management risks (e.g., errors, cost overrun, scope creep, and missing milestones). A combination of management and the project manager or sponsor are responsible for monitoring and controlling the entire project throughout all phases.

During the initiation phase, monitoring and controlling activities include the following:

- Validating that relevant stakeholders are identified and all stakeholders' project requirements are well-defined.
- Coordinating the project phases, including tasks and activities, sufficiency of resources, and process steps and timing for each phase.
- Validating that the project scope is sufficiently identified and refined to minimize scope creep.
- Evaluating the application of project management policy, standards, and procedures.
- Validating that appropriate success criteria are identified and the project is feasible.
- Determining effective establishment of reporting lines, reporting processes, and reports.

During the planning phase, monitoring and controlling activities include the following:

- Validating the appropriateness of the project plan's tasks and time frames as well as resource sufficiency.
- Reviewing the project plan iteratively and validating any approvals for any updates.
- Validating stakeholder support and engagement.
- Verifying that the project plan and associated project documents are appropriate, comprehensive, and approved.

During the execution phase, monitoring and controlling activities include the following:

- Meeting regularly with the project team to track progress, address impediments or issues, and track task and milestone completion.
- Monitoring, measuring, and analyzing project performance compared to the project plan and identifying any variance.
- Validating that any changes are authorized, quality is maintained, scope creep is mitigated, and stakeholders are informed.
- Recommending corrective or preventive action.
- Verifying that configuration management policies and procedures are followed.
- Monitoring expenditures compared to the project budget and addressing any cost overruns.

During the closeout phase, monitoring and controlling activities include the following:

- Validating that the project team follows closeout processes when the project is complete.
- If a project is discontinued before implementation, determining and documenting the reasons for the abnormal project closure for use by future project teams.
- Verifying that project deliverables were accepted.
- Overseeing a post-implementation review.
- Confirming that the system or components have been added to inventories that support routine maintenance, such as patching.

IV.N.3 IT Project Documentation

IT project documentation helps ensure clear communication among the project team, management, and other stakeholders. For example, strong written documentation provides a record of key decisions (e.g., project approvals, timeline, and scope changes) that the project team can refer to throughout the project.

Types of IT project documentation range from simple documents, such as meeting minutes and project status reports, to more complex documents such as feasibility studies, project plans, requirements, and PIRs. Project documentation allows management to track and monitor security, resilience, and compliance concerns throughout the project and after its completion. Entities establish documentation standards and procedures to mitigate the risk of inconsistent or incomplete documentation. When determining the amount of project documentation needed, various factors to consider include an entity's size and complexity, the project type (e.g., development, acquisition, or maintenance), and the project's complexity. The following subsections describe common examples of project documentation.

IV.N.3(a) IT Project Request

IT project requests outline proposed projects including the reason for initiating the project. Effective project requests convey proposed business objectives and project requirements between the project team, management, and other stakeholders. Project requests also identify project responsibility and accountability, including identifying the project sponsor. Project requests often include the following:

- Project sponsor.
- Customer or user.
- Other stakeholders.
- Purpose and proposed scope of the project.
- Project deliverables.
- Project constraints (e.g., time, budget, and technology).
- Business case.¹³¹

¹³¹ A business case generally accompanies the project request and provides additional information to help set appropriate parameters for the project.

IV.N.3(b) *Business Case*

A business case conveys business related information to help management determine whether to fund a project. The goal is to justify the project resources (e.g., budget and staffing) to address a business need. Typically, the project's sponsor helps to develop and owns the resulting business case.¹³² Business cases often include the following:

- The need or problem the project will address (e.g., systems not meeting operational requirements or loss of market share).
- Alternative solutions including estimated staffing, timeline, costs, benefits, and risks.
- The proposed solution with rationale (e.g., buy a new system or develop a new component).

Effective business cases address both the parameters for implementing and maintaining the solution. For example, both the costs to build and maintain various system options are analyzed before a proposed solution is presented.

IV.N.3(c) *Feasibility Study*

A feasibility study is an analysis of a known problem or need and the proposed solution conducted independent of the project request team. It helps stakeholders evaluate a proposed solution considering relevant factors—including economic, technical, legal, and scheduling considerations—to determine a project's probability of success. Table 2 outlines feasibility study considerations.

Table 2: Feasibility Study Considerations

Business considerations	• Entity objectives. • Effect on existing operations. • IT security risk assessment to determine security risks and mitigation needs. • Entity's IT and information security requirements addressing data confidentiality, integrity, availability, and resilience. • Expected benefits. • Potential entity changes regarding facilities or the addition or reduction of users, IT staff, key security roles, or managers. • Budget, scheduling, training, or personnel constraints (including for oversight of third-party relationships). • Licensing needs. • Potential legal or regulatory issues that could affect the project's feasibility. • Estimated completion dates of IT projects and major project milestones. • Expected benefits and risks for consumers relative to the new product or service. • Third party's due diligence throughout the supply chain.
Functional requirements	• End user needs. • Internal control and information security requirements. • Operating, database, and backup system requirements (e.g., type, capacity, performance, scalability, and resiliency). • Hardware requirements (e.g., infrastructure needs, processing chips, and credit card or point-of-sale components). • Facility needs (e.g., raised floor, cabling, and heating, ventilation, and air conditioning [HVAC]).

¹³² Refer to PMI, "[Is This Really Worth the Effort? The Need for a Business Case.](#)"

	• Network requirements (e.g., physical, virtual, software-defined, and hyper-converged networks; types of storage; number of users; and type, volume, and frequency of data transmission). • Connectivity and interface requirements with internal or external applications, third-party service providers, internal or external users, and customers. • Third-party hardware and software vendor requirements related to entity functional requirements. • Product development, design, and testing standards throughout the supply chain. • Supply chain considerations related to entity business considerations and functional requirements. • Entity's requirements compared to third-party products, services, and activities implemented in the supply chain.
Cost-benefit analysis	• Expected useful life of the proposed product or application. • Alternative solutions (e.g., build or buy). • Estimated costs of projects (e.g., overall and by project phase). ◦ Nonrecurring project costs (e.g., hardware, software, and overhead). ◦ Recurring operational costs (e.g., personnel, maintenance, telecommunications, and overhead). • Soft (or intangible) costs.¹³³ • Tangible benefits (e.g., increased revenues, decreased costs, and return on investment). • Intangible benefits (e.g., improved public opinion or more useful information).

IV.N.3(d) *IT Project Plans*

IT project plans describe how a project will be executed, monitored and controlled, and closed. Entities use project plans to communicate tasks, time frames, and responsible parties to project stakeholders throughout a project. The details in an IT project plan identify necessary technical steps in sequence and help the team identify any missing tasks that are needed to achieve the project's objectives. The project plan also identifies interconnectivities and interdependencies throughout the project—how segments of the project are interrelated. Generally, IT project plans consider the following:

- Approved project scope.
- Roles and responsibilities.
- Communication among the project team, stakeholders, and management.
- Schedule, including completion of key tasks and achieving milestones.
- Quality management tasks (e.g., testing both developed systems and patches for procured systems).
- Risk management tasks (e.g., periodic risk reviews).
- Task budgets.
- Implementation tasks (e.g., training and deployment).

IV.N.3(e) *Closeout Documentation*

Entities use closeout documentation to apply lessons learned from past projects to future projects. These lessons can include practices and techniques that were effective, problems that could be avoided if particular processes are used, and how high-performing project teams were

¹³³ Soft costs generally include indirect dollars spent in other areas (e.g., sales, general, and administrative expenses) to support a change in business model, equipment, or practices.

formed. Many lessons can be memorialized by updating existing policies, procedures, and standards. Several documents can be used to improve future projects, such as the following:

- Project plans with projected and final task completion dates.
- PIR.
- Risk reviews including suggested changes to project management-related policies, standards, and procedures.

IV.O System Development Life Cycle

Action Summary

Management should implement an SDLC to manage systems and system components throughout their life cycle and achieve the objectives of confidentiality, integrity, availability, and resilience to achieve the entity's business objectives.

Examiners should review the following:

- The documented management and control processes, including for supply chain partners.
- Responsibility and accountability assignment.
- Key stakeholder involvement level.
- Stakeholder communication and tracking of all SDLC phases and actions.

One NIST SDLC definition is that it is “the scope of activities associated with a system, encompassing the system’s initiation, development and acquisition, implementation, ongoing operation and maintenance, and ultimately its disposal that instigates another system initiation.”¹³⁴ The acronym SDLC is also used to refer only to software development and implementation (standing for the software development life cycle). However, this booklet uses the acronym SDLC to refer to the broader concept encompassing the entire system and its components. If an entity engages in internal development activities, management should have a documented process (e.g., SDLC) that management and personnel use to manage and control development activities. Effective SDLC processes are well-documented by organizations such as NIST.¹³⁵ Using proven processes helps to mitigate the various risks of building, maintaining, and retiring systems. Implementing the SDLC allows management to organize these activities into smaller, more manageable segments or phases. Data security should be considered throughout all phases of the SDLC to maintain confidentiality, integrity, availability, and resilience.

The SDLC discipline discussed in this section and the project management discipline discussed in the last section overlap significantly. In practice, effective system and component development teams integrate discipline use without duplicating effort.

¹³⁴ Refer to [NIST Glossary](#).

¹³⁵ Refer to NIST SP 800-160, vol. 1, rev. 1, [Engineering Trustworthy Secure Systems](#).

IV.O.1 SDLC Phases

Action Summary

During the SDLC phases, system development project teams work to achieve project objectives, mitigate the risk of lower quality development projects, and address security. These considerations are considered throughout all phases.

Examiners should review elements of each phase such as the following:

Initiation Phase

- The system's purpose, expected benefits, how it supports business objectives, and any legal and regulatory requirements.
- Initial security impact analysis and validation of the appropriate project specifications.
- Extent to which the project request is communicated to stakeholders in the supply chain.

Development or Acquisition Phase

- Design specifications, including security control design.
- Risk assessments, including using the results of security risk assessment, to supplement the baseline security controls.
- Risk mitigation strategies.
- Test, conversion, implementation, and training plans, accounting for confirmation of the functionality and controls.
- Change management documentation.
- Draft user, operator,¹³⁶ and maintenance manuals.

Implementation and Assessment Phase

- Design reviews and system tests, including any new specification testing.
- Deployment approach (e.g., phased-in, simultaneous).
- Training, including user and system support documentation.
- PIR.

Operations and Maintenance Phase

- Performance and controls monitoring.
- Change management controls, including as used to control configurations.
- ITAM inventory and associated audits.

Sunset and Disposal Phase

- Plans and validation measures for accessing and retrieving data from archives.
- Off-boarding procedures, including for third-party providers.
- The entity's post-disposal review, including any lessons learned documentation.

¹³⁶ Refer to [NIST Glossary](#).